Annex D. Project risk register

María de los Ángeles Olaya García; Jhon Jairo Cortez Vargas

Servicio Nacional de Aprendizaje (SENA), Programa ADSO-3145556

Instructora: Karol Daniela Correa

12 de octubre de 2026

Annex D. Project risk register

Source: 15-project-control/risks.md, prepared from the source-code audit of October 8, 2026. Summary adapted from the original.

1. Active risks

• | ID | Risk and description | Level | Strategy | Owner and review |

• |---|---|---|---|---|

• | R-001 | Identity spoofing via X-User- headers. Services accept X-User-Id and X-User-Role without checking where they come from; anyone who reaches a service port directly can impersonate an ADMIN | Critical | Mitigate | Backend, Oct 31, 2026 |

• | R-002 | RSA private key committed in ms-security. dev-private.pem is in the repository and is the default key; the superadmin account is also seeded with a default password | Critical | Mitigate | Backend, Oct 15, 2026 |

• | R-003 | Open CORS with credentials on the gateway. All origins are allowed with credentials; the CORS_ALLOWED_ORIGINS variable exists but no code reads it | High | Mitigate | Backend, Oct 31, 2026 |

• | R-004 | Coverage unenforced despite NFR-006. The strategy requires 80% line coverage, but no pom.xml has JaCoCo; there are no contract, E2E or performance tests and the frontends have no tests | High | Mitigate | QA, Nov 15, 2026 |

• | R-005 | ms-user-experience missing from Kubernetes and CI. It runs under Docker Compose but has no Deployment or PostgreSQL in deploy/k8s/ and is not in the pipeline matrix | High | Avoid | DevOps, Oct 31, 2026 |

• | R-006 | Decorative observability. Prometheus scrapes /actuator/prometheus but no service includes actuator or micrometer; Grafana has no data sources or dashboards | High | Mitigate | DevOps, Nov 15, 2026 |

• | R-007 | Drift between ADR-003 and the deployment. The ADR requires one PostgreSQL instance with a schema per service, but Compose and k8s run six independent servers; HistoricalBackfillService joins schemas from different databases and cannot work that way | Medium | Avoid | Backend, Nov 30, 2026 |
• | R-008 | Circuit breaker documented but not implemented. Without it, an ms-security outage leaves the gateway unable to degrade gracefully | Medium | Accept | Backend, Dec 15, 2026 |
• | R-009 | Device firmware off-contract. Two unconsolidated firmwares exist: one posts over plain HTTP and forges ADMIN headers, and the other does not compile and targets the wrong service and port | Medium | Mitigate | IoT, Nov 15, 2026 |
• | R-010 | Frontend with no tests or shared contracts. Web and mobile have no tests, the API layer is duplicated and diverging, and the mobile app was written against an API that does not exist | Medium | Mitigate | Frontend, Nov 30, 2026 |
• | R-011 | Documentation describing things that do not exist. Jenkins is declared as CI (the real one is GitHub Actions), 6 UML diagrams have no source file, a port is wrong in local-setup.md and about 18 referenced files do not exist | Medium | Mitigate | Whole team, Oct 31, 2026 |

2. Closed risks and lessons learned

• | ID | Risk | Outcome |
• |---|---|---|
• | R-012 | ms-security tokens did not interoperate with the other services (HS256 with a shared secret vs RS256) | Occurred. Closed Oct 8, 2026: the five services validate RS256 against the ms-security JWKS |
• | R-013 | The ms-classroom-management outbox never published (missing table, missing @EnableScheduling and events carrying random UUIDs) | Occurred. Closed Oct 8, 2026. Lesson: a feature with no integration test breaks without anyone noticing |

• | R-014 | The event pipeline had no producers: monitoring consumed events that nobody published | Occurred. Closed Oct 8, 2026 with the installation outbox |
• | R-015 | Live metrics never reached the frontend (score always 100, temperature undefined) | Occurred. Closed Oct 8, 2026 with GET /api/v1/environments/current. Lesson: the UI must not assume fields that no endpoint provides |

3. Relation to the test plan

Risks R-002 and R-003 relate to case SEC-012 (do not expose secrets) and to section 11.2 of the plan; R-004 and R-010 explain why WEB and MOB are manual cases; R-009 explains why IOT-008 is blocked. The status of each risk should be reviewed on the date shown before the final presentation.